



Governance, Risk & Compliance (GRC) Portfolio

Version 1.0

Information Security Governance Documentation

Prepared by: Alaa Mohamed Abdelatif

Aspiring GRC Analyst

ISO/IEC 27001 Governance Portfolio 2026

Executive Summary

This portfolio presents a practical Governance, Risk and Compliance (GRC) programme developed for CloudCare Medical, a fictional healthcare organisation. The project demonstrates the implementation of information security governance practices aligned with ISO 27001 principles.

The portfolio includes key governance documents such as an ISO 27001 Gap Assessment, Asset Inventory, Vendor Risk Register, Security Audit Checklist, Risk Register and Incident Response Tracker. Together, these documents illustrate how organisations identify risks, assess compliance obligations, manage third-party relationships and respond to security incidents.

The objective of this portfolio is to demonstrate practical understanding of information security governance, risk management, compliance monitoring and operational resilience. The documentation reflects industry-standard approaches commonly used by Information Security, Compliance and Risk Management teams.

Introduction

This portfolio demonstrates the practical application of Governance, Risk and Compliance (GRC) principles within a fictional healthcare organisation, CloudCare Medical. The project was developed to showcase knowledge of information security governance, risk management, compliance monitoring and ISO 27001 controls.

The portfolio contains a collection of security and compliance documents commonly used within organisations to manage cyber security risks, support regulatory compliance and improve operational resilience.

Portfolio Objectives

- Demonstrate understanding of ISO 27001 concepts and controls.
- Illustrate risk identification and treatment processes.
- Show practical use of governance and compliance documentation.
- Develop professional documentation using Microsoft Excel.
- Present information in a format commonly used within security and compliance teams.

Portfolio Contents

01. ISO 27001 Gap Assessment

This document identifies existing security gaps against ISO 27001 requirements. The assessment highlights weaknesses, assigns risk ratings and provides recommendations for remediation activities.

CloudCare Medical – ISO 27001 Gap Assessment							
Control Area	ISO27001 Domain	Current Status	Gap Identified	Risk Level	Recommendation	Responsible Owner	Target Date
Access Control	Access Management	Partial	MFA not enforced for all users	High	Implement mandatory MFA across all systems	IT Security Team	Q3 2026
Password Management	Identity Security	Implemented	Password review schedule not documented	Medium	Establish password review procedure	IT Team	Q2 2026
User Account Reviews	Access Governance	Partial	Dormant accounts not reviewed regularly	High	Perform quarterly access reviews	Compliance Team	Q3 2026
Vendor Risk Management	Supplier Security	Partial	No formal vendor assessment workflow	High	Create vendor risk assessment process	Governance Team	Q3 2026
Incident Response	Security Incident Management	Implemented	No tabletop incident exercises conducted	Medium	Schedule annual incident response testing	Security Team	Q4 2026
Asset Inventory	Asset Management	Partial	Several cloud assets undocumented	High	Maintain centralised asset inventory	Infrastructure Team	Q2 2026
Backup Management	Business Continuity	Implemented	Backup restoration testing incomplete	Medium	Conduct quarterly recovery testing	Infrastructure Team	Q3 2026
Encryption Controls	Cryptography	Partial	Encryption standards inconsistent	High	Standardise encryption requirements	Security Engineering	Q3 2026
Data Retention	Information Lifecycle	Partial	Retention periods undefined for some records	Medium	Create formal retention schedule	Compliance Team	Q2 2026
Data Classification	Information Governance	Implemented	Staff awareness training incomplete	Medium	Conduct classification awareness training	HR & Security Team	Q2 2026
Security Awareness Training	Human Resource Security	Partial	Training completion tracking absent	Medium	Implement training monitoring dashboard	HR Department	Q3 2026
Logging & Monitoring	Monitoring Activities	Partial	Security logs retained inconsistently	High	Define standard log retention periods	SOC Team	Q3 2026
Vulnerability Management	Technical Security	Partial	Vulnerability scans not scheduled regularly	High	Introduce monthly vulnerability scanning	Security Operations	Q2 2026
Patch Management	System Maintenance	Partial	Critical patch timelines undefined	High	Implement patch management policy	IT Operations	Q2 2026
Mobile Device Security	Endpoint Protection	Partial	BYOD controls not documented	Medium	Develop mobile device security standard	IT Governance	Q3 2026
Cloud Security	Cloud Governance	Partial	Cloud configuration reviews inconsistent	High	Conduct periodic cloud security reviews	Cloud Security Team	Q3 2026
Physical Security	Physical & Environmental Security	Implemented	Visitor logging process manual only	Low	Introduce digital visitor tracking	Facilities Team	Q4 2026
Business Continuity Planning	Operational Resilience	Partial	Recovery objectives not fully documented	High	Define RTO and RPO requirements	Business Continuity Team	Q3 2026
Third-Party Access	Supplier Access Control	Partial	External user access approvals undocumented	High	Formalise third-party access approval process	Compliance Team	Q2 2026
Audit Management	Internal Audit	Partial	Audit evidence stored inconsistently	Medium	Centralise audit documentation storage	Governance Team	Q3 2026
Risk Management	Risk Governance	Implemented	Risk reviews not scheduled consistently	Medium	Conduct quarterly risk review meetings	Risk Management Team	Q2 2026
Secure Disposal	Media Handling	Partial	Disposal verification records incomplete	Medium	Maintain disposal certificates and logs	IT Asset Team	Q3 2026
Remote Access Security	Network Security	Partial	VPN monitoring limited	High	Enhance VPN logging and monitoring	Network Security Team	Q2 2026
Data Loss Prevention	Data Protection	Partial	DLP controls not implemented organisation-wide	High	Deploy enterprise DLP solution	Security Engineering	Q4 2026
Compliance Reporting	Regulatory Compliance	Partial	GDPR compliance reporting manual	Medium	Automate compliance reporting workflows	Compliance Officer	Q4 2026

02. Asset Inventory

This document maintains a register of organisational assets including systems, databases and cloud services. Asset inventories are essential for risk management, data protection and security governance.

CloudCare Medical – Asset Inventory								
Asset ID	System Name	Owner	Classification	Criticality	Location	Backup Status	MFA Enabled	Encryption Status
AST-001	Patient Records System	IT Operations	Restricted	High	AWS Cloud	Daily	Yes	Encrypted
AST-002	HR Management Portal	HR Department	Confidential	Medium	Azure Cloud	Weekly	Yes	Encrypted
AST-003	Finance Database	Finance Team	Restricted	High	On-Premise	Daily	Yes	Encrypted
AST-004	Email Server	Infrastructure Team	Internal	High	Microsoft 365	Daily	Yes	Encrypted
AST-005	Vendor Management Portal	Governance Team	Confidential	Medium	AWS Cloud	Weekly	Yes	Encrypted
AST-006	Backup Storage Server	Infrastructure Team	Restricted	High	Data Centre	Daily	Yes	Encrypted
AST-007	Security Monitoring System	SOC Team	Restricted	High	Azure Cloud	Daily	Yes	Encrypted
AST-008	Employee Laptop Fleet	IT Support	Internal	Medium	Leeds Office	Weekly	Partial	BitLocker Enabled
AST-009	Mobile Device Management	IT Governance	Internal	Medium	Intune Cloud	Daily	Yes	Encrypted
AST-010	Compliance Documentation Repository	Compliance Team	Confidential	Medium	SharePoint Online	Weekly	Yes	Encrypted

03. Third-Party Vendor Risk Register

This register tracks third-party suppliers and assesses their security risks, compliance status and review requirements. Effective vendor risk management reduces exposure to supply chain threats.

CloudCare Medical – Third-Party Vendor Risk Register										
Vendor Name	Service Type	Data Access	Risk Level	Compliance Status	Contract Expiry	Security Review	MFA Requirement	Responsible Owner	Review Status	
Microsoft Azure	Cloud Hosting	Restricted	High	Compliant	12/12/2026	Completed	Required	Infrastructure Team	Approved	
AWS	Auxiliary Cloud Services	Restricted	High	Compliant	05/11/2026	Completed	Required	Cloud Security Team	Approved	
Google Workspace	Email & Collaboration	Confidential	Medium	Compliant	03/08/2026	Completed	Required	IT Governance	Approved	
DocuSign	Digital Signatures	Confidential	Medium	Compliant	09/01/2027	Completed	Required	Compliance Team	Approved	
Salesforce	CRM Platform	Confidential	Medium	Under Review	15/02/2026	Pending	Required	Operations Team	Review Required	
CrowdStrike	Endpoint Security	Restricted	High	Compliant	21/06/2027	Completed	Required	SOC Team	Approved	
Zoom	Video Conferencing	Internal	Low	Compliant	30/09/2026	Completed	Recommended	HR Department	Approved	
Okta	Identity Management	Restricted	High	Compliant	19/04/2027	Completed	Required	Identity Team	Approved	
Slack	Internal Messaging	Internal	Medium	Under Review	11/07/2026	Pending	Recommended	IT Operations	Review Required	
ServiceNow	IT Service Management	Confidential	Medium	Compliant	27/10/2026	Completed	Required	IT Governance	Approved	

04. Security Audit & Compliance Checklist

This document monitors security controls, audit evidence and compliance requirements. It supports internal audits and demonstrates ongoing governance activities.

CloudCare Medical – Security Audit & Compliance Checklist							
Control Area	Audit Requirement	Current Status	Evidence Available	Compliance Rating	Last Review Date	Responsible Team	Action Required
Password Policy	MFA enforced for privileged users	Compliant	Yes	High	12/05/2026	IT Security Team	None
Access Control	Quarterly user access reviews	Partial	Partial	Medium	02/04/2026	Compliance Team	Review inactive accounts
Backup Management	Backup restoration testing	Non-Compliant	No	High	15/03/2026	Infrastructure Team	Conduct recovery testing
Vendor Security	Third-party security assessments	Partial	Partial	Medium	10/05/2026	Governance Team	Update vendor reviews
Security Awareness	Employee phishing simulations	Compliant	Yes	Low	01/06/2026	HR & Security Team	None
Incident Response	Annual tabletop exercises	Partial	Partial	Medium	18/02/2026	SOC Team	Schedule exercise
Patch Management	Critical patch deployment within SLA	Non-Compliant	No	High	22/04/2026	IT Operations	Improve patch timelines
Data Retention	GDPR retention compliance	Compliant	Yes	Low	07/06/2026	Compliance Team	None
Logging & Monitoring	Security logs retained for 12 months	Partial	Partial	Medium	25/03/2026	SOC Team	Expand log retention
Mobile Device Security	MDM controls enabled	Compliant	Yes	Low	14/05/2026	IT Governance	None

05. Risk Register

The risk register records identified risks, evaluates likelihood and impact, assigns ownership and documents risk treatment plans.

CloudCare Medical – Risk Register							
Risk ID	Risk Description	Category	Likelihood	Impact	Risk Score	Owner	Treatment Plan
RISK-001	Ransomware attack affecting patient systems	Cyber Security	High	High	9	IT Security Team	Implement advanced endpoint protection
RISK-002	Loss of sensitive patient records	Data Protection	Medium	High	6	Compliance Team	Improve data retention controls
RISK-003	Cloud service outage	Operational	Medium	High	6	Infrastructure Team	Deploy disaster recovery solution
RISK-004	Weak password practices	Access Control	High	Medium	6	IT Operations	Implement MFA and password policy
RISK-005	Vendor security breach	Third Party	Medium	High	6	Governance Team	Perform quarterly vendor assessments
RISK-006	Phishing attack against staff	Cyber Security	High	Medium	6	HR & Security Team	Conduct awareness training
RISK-007	Failure of backup restoration	Business Continuity	Medium	High	6	Infrastructure Team	Perform quarterly recovery tests
RISK-008	Unpatched critical vulnerabilities	Technical Security	High	High	9	Security Operations	Implement monthly patch reviews
RISK-009	GDPR non-compliance	Compliance	Medium	High	6	Compliance Officer	Perform internal audits
RISK-010	Unauthorized remote access	Network Security	High	High	9	Network Security Team	Enhance VPN monitoring

06. Incident Response Tracker

This document tracks security incidents, root causes, corrective actions and closure activities. It supports continuous improvement and incident management processes.

CloudCare Medical – Incident Response Tracker								
Incident ID	Date Reported	Incident Type	Severity	Status	Assigned Team	Root Cause	Corrective Action	Closure Date
INC-001	03/01/2026	Phishing Email	High	Closed	SOC Team	User clicked malicious link	Implemented phishing awareness training	10/01/2026
INC-002	15/01/2026	Unauthorized Access	High	Closed	IT Security Team	Weak password reused	Enforced MFA and password reset	20/01/2026
INC-003	02/02/2026	Malware Detection	Medium	Closed	Security Operations	Outdated endpoint protection	Updated endpoint security software	08/02/2026
INC-004	18/02/2026	Data Leakage	High	In Progress	Compliance Team	Misconfigured file permissions	Review and tighten permissions	
INC-005	05/03/2026	VPN Failure	Medium	Closed	Network Team	Firewall configuration issue	Updated firewall rules	07/03/2026
INC-006	22/03/2026	Lost Laptop	Medium	Closed	IT Operations	Device left unattended	Reinforced device handling policy	25/03/2026
INC-007	10/04/2026	Ransomware Attempt	High	Closed	SOC Team	Malicious email attachment	Blocked sender and updated filters	12/04/2026
INC-008	28/04/2026	Privilege Escalation	High	In Progress	IT Security Team	Excessive user permissions	Review privileged access controls	
INC-009	11/05/2026	System Outage	Medium	Closed	Infrastructure Team	Server resource exhaustion	Capacity planning/improvements	13/05/2026
INC-010	30/05/2026	Policy Violation	Low	Closed	HR & Security Team	Employee non-compliance	Refresher policy training	31/05/2026

Key Skills Demonstrated

- Governance and Compliance Monitoring
- ISO 27001 Awareness
- Information Security Governance
- Risk Assessment and Treatment
- Incident Management
- Vendor Risk Management
- Asset Management
- Audit Preparation
- Documentation Management
- Microsoft Excel Reporting

Conclusion

This portfolio demonstrates practical application of Governance, Risk and Compliance (GRC) principles aligned with ISO/IEC 27001. Through the development of governance documentation, risk management records, compliance monitoring tools and incident management trackers, the project showcases key competencies relevant to Information Security and GRC functions.

The portfolio reflects an understanding of risk assessment, asset management, third-party risk management, audit preparation and compliance reporting. These documents represent examples of the types of records commonly maintained within security and compliance teams and demonstrate readiness for entry-level GRC and Information Security Analyst roles.